

Recommandations RGPD – Conformité du CRM

Dans le cadre de la mise en conformité du CRM avec le Règlement Général sur la Protection des Données (RGPD), les recommandations suivantes visent à garantir la protection des données personnelles, la limitation de leur utilisation et la traçabilité des traitements conformément aux exigences de la CNIL.

Les recommandations sur les règles de gestion à mettre en place sur les données du CRM pour être conforme au RGPD sont :

1. Minimisation des données :

- Ne conserver que les données strictement nécessaires à la finalité déclarée (gestion de la relation client et des devis d'assurance) :
- Supprimer ou archiver les données non nécessaires à la finalité commerciale ou au traitement des devis :

Exemple : groupe_sanguin, num_ss, valeur_residence_prin, id_site_web (non essentiels à la gestion d'un devis d'assurance auto).

- Conserver uniquement les champs utiles à la gestion des dossiers :

Exemple : usage_vehicule, type_vehicule, points_perdus, tarif_devis, formule, etat_dossier, revenus, date_demande.

2. Anonymisation et pseudonymisation des données personnelles :

- Rendre impossible toute identification directe ou indirecte d'une personne.
- Supprimer ou remplacer les identifiants directs : nom, email, adresse, num_ss, id_site_web.
- Pseudonymiser l'identifiant client : Remplacer id_client par un identifiant aléatoire non traçable.
- Anonymiser les données sensibles ou indirectement identifiantes :

- Date_naissance : remplacer par tranche d'âge (ex. [18–25], [26–40], [41–60], etc.)
- Revenus : convertir en intervalle ([0–20k], [20k–40k], etc.).
- Nombre_enfants et enfant_conduite_accompagnee : transformer en binaire : Oui/Non.
- Lat et lon → arrondir ou supprimer pour éviter la géolocalisation précise.

3. Limitation de la durée de conservation

- Garantir que les données personnelles ne soient pas conservées au-delà de la période nécessaire.
- Mettre en place un calendrier de rétention des données : suppression automatique ou anonymisation des données après expiration de leur durée de conservation légale ou contractuelle. Les durées doivent être définies selon le type de donnée (client actif, prospect, etc.) et documentées dans le registre de traitement.

➤ Définir des durées de rétention par catégorie :

- Données de prospects : suppression après 3 ans sans contact.
- Données de clients actifs : conservation pendant la durée du contrat + 5 ans.

4. Sécurisation et contrôle des accès :

- Garantir que seules les personnes habilitées accèdent aux données pertinentes.
- Restreindre les droits selon les rôles :
 - L'équipe Performance commerciale : accès uniquement aux champs anonymisés et agrégés (sans tarif_devis, revenus précis, adresse, email, nom).
 - L'équipe Direction : accès global mais encadré par des journaux d'audit.
- Masquer ou supprimer les données tarifaires détaillées (tarif_devis) dans les exports CSV partagés.
- Utiliser une authentification forte pour l'accès au CRM (mot de passe).
- Activer un journal d'accès et d'extraction : consigner qui a exporté quoi et quand.

5. Transparence et Droit des personnes :

- Les personnes doivent être informées de l'utilisation des données les concernant et de la manière dont ils peuvent exercer leurs droits.
- Assurer une transparence totale et une preuve de conformité en cas de contrôle CNIL.
- Les personnes bénéficient de nombreux droits qui leur permettent de garder la maîtrise de leurs données :
 - Droit d'accès
 - Droit de rectification
 - Droit de suppression
 - Droit d'opposition
 - Droit à la portabilité
 - Droit à la limitation du traitement
 - Droit de définir le sort des données après la mort
 - Droit de ne pas faire l'objet d'une décision automatisée